

1. What is OWASP ZAP (simple explanation)

OWASP ZAP (Zed Attack Proxy) is a **DAST tool (Dynamic Application Security Testing)** used to find security vulnerabilities in running web applications.

👉 It tests the application **from outside**, like a hacker.

2. Where it fits in DevSecOps pipeline

Show this flow:

Code → Build → SonarQube (SAST) → Docker Image → Trivy → Deploy → OWASP ZAP (DAST)

👉 ZAP is the **last security gate after deployment**

3. What you scanned (very important)

Mention clearly:

- Application URL (LoadBalancer / Kubernetes service)

Example:
http://<LB-URL>

-

👉 NOT Jenkins

4. Types of scan used

Say:

- ✓ Baseline scan (`zap-baseline.py`)
 - ✓ Passive scanning (no attack, safe scan)
 - ✓ Automated spider crawling
-

5. What ZAP checked

Explain in simple categories:

Security headers

- CSP (Content Security Policy)
- HSTS
- X-Frame-Options

Cookie security

- HttpOnly flag
- Secure flag
- SameSite attribute

Vulnerability checks

- XSS (Cross-Site Scripting)
 - Sensitive data exposure
 - Open redirects
 - Debug information leaks
-

6. Your results (IMPORTANT SLIDE)

From your output:

Passed checks

- 56 PASS
- Secure cookies mostly OK
- No critical vulnerabilities found

Warnings (normal in baseline scan)

- Missing CSP header
- Missing security headers
- Information disclosure warnings

Failures

- 0 FAIL (GOOD SIGN 🎉)

 Key message:

No critical vulnerabilities detected

7. Example findings (good to show)

Pick 2–3 only:

Example 1:

- Missing Content Security Policy (CSP)

Example 2:

- Cookie missing Secure flag

Example 3:

- Server version exposure
-

8. What “WARN” means (important interview point)

Explain:

- WARN ≠ vulnerability
 - It means **potential security improvement**
 - Needs developer attention
-

9. Output artifact

Show:

- `zap-report.html`
- Jenkins archived artifact

👉 This proves automation

10. Key takeaway (final slide)

Say:

- Integrated DAST into CI/CD pipeline
 - Automatically scans deployed app
 - Helps detect security issues early
 - Improves application security posture
-

? Why ZAP in DevSecOps?

👉 Because it simulates real attacker behavior on running app

? Why not only SonarQube?

👉 SonarQube = code-level

👉 ZAP = runtime-level attack simulation

? Why baseline scan?

👉 Safe, automated, CI-friendly

👉 “OWASP ZAP is a DAST tool that tests our deployed application for security vulnerabilities like XSS, insecure headers, and data leaks in an automated CI/CD pipeline.”

🟡 Medium Risk (⚠️ MAIN WARNINGS)

These are your **real security warnings**:

1. CSP issues (VERY IMPORTANT)

- CSP not set
 - CSP directives missing fallback
 - 👉 This means your app is weak against XSS
-

2. Cross-Domain Misconfiguration (CORS issue)

- `Access-Control-Allow-Origin: *`

👉 This is a **major warning**

✓ Allows any website to call your API

3. Missing Anti-clickjacking Header

- No `X-Frame-Options`
- No CSP frame-ancestors

👉 Risk: your site can be embedded in iframe attacks

Low Risk (Minor warnings)

These are **security hardening warnings**:

4. Missing security headers

- Cross-Origin-Opener-Policy missing
 - Cross-Origin-Embedder-Policy missing
 - Permissions Policy missing
 - X-Content-Type-Options missing
-

5. Information leakage

- `X-Powered-By: Express`

👉 Not dangerous alone, but reveals backend tech

Informational (NOT warnings)

These are NOT security issues:

- Modern Web Application
- Cacheable content